

Identifying and Exploiting Network Vulnerabilities Lab

Jason Man

8/4/26

Part 1: Network Discovery and Enumeration

- Nmap utilized for discovering live hosts on the subnet 10.10.20.0/24 confirms the banking server-target host(10.10.20.4) is up

```
(student01@kali)-[~]  
$ nmap -sn 10.10.20.0/24  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 04:18 +0000  
Nmap scan report for victim.internal.cloudapp.net (10.10.20.4)  
Host is up (0.0014s latency).  
Nmap done: 256 IP addresses (1 host up) scanned in 3.96 seconds  
  
(student01@kali)-[~]  
$
```

- An Nmap port and version scan is used on the banking server-target host IP (10.10.20.4) so every open port and their service and version can be recorded in the table below and used to cross reference vulnerabilities and exploits later

```
(student01@kali)-[~]  
$ nmap -sV -sC -p- 10.10.20.4 -oN scan_results.txt  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 04:20 +0000  
Nmap scan report for victim.internal.cloudapp.net (10.10.20.4)  
Host is up (0.0021s latency).  
Not shown: 65518 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          FileZilla ftpd 1.12.6  
|_ tls-alpn:  
|_   ftp  
|_ ftp-syst:  
|_   SYST: UNIX emulated by FileZilla.  
|_ ssl-cert: Subject: commonName=filezilla-server self signed certificate  
|_ Not valid before: 2026-07-29T20:30:04  
|_ Not valid after: 2027-07-30T20:35:04  
|_ ftp-anon: got code 503 "Use AUTH first."  
80/tcp    open  http         Microsoft IIS httpd 10.0  
|_ http-title: IIS Windows Server  
|_ http-server-header: Microsoft-IIS/10.0  
|_ http-methods:  
|_   Potentially risky methods: TRACE  
135/tcp   open  msrpc        Microsoft Windows RPC  
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn  
445/tcp   open  microsoft-ds?   
1433/tcp  open  ms-sql-s     Microsoft SQL Server 2019 15.00.2000.00; RTM  
|_ ssl-date: 2026-08-05T04:24:14+00:00; +2s from scanner time.  
|_ ms-sql-info:  
|_   10.10.20.4\MSSQLSERVER:  
|_     Instance name: MSSQLSERVER  
|_     Version:  
|_       name: Microsoft SQL Server 2019 RTM  
|_       number: 15.00.2000.00  
|_       Product: Microsoft SQL Server 2019  
|_       Service pack level: RTM  
|_       Post-SP patches applied: false  
|_     TCP port: 1433  
|_     Clustered: false  
|_ ms-sql-ntlm-info:  
|_   10.10.20.4\MSSQLSERVER:  
|_     Target_Name: victim  
|_     NetBIOS_Domain_Name: victim  
|_     NetBIOS_Computer_Name: victim  
|_     DNS_Domain_Name: victim  
|_     DNS_Computer_Name: victim  
|_     Product_Version: 10.0.20348  
|_ ssl-cert: Subject: commonName=SSL Self Signed Fallback
```

```

ssl-cert: Subject: commonName=victim
Not valid before: 2026-07-28T18:49:40
Not valid after: 2027-01-27T18:49:40
rdp-ntlm-info:
  Target_Name: victim
  NetBIOS_Domain_Name: victim
  NetBIOS_Computer_Name: victim
  DNS_Domain_Name: victim
  DNS_Computer_Name: victim
  Product_Version: 10.0.20348
  System_Time: 2026-08-05T04:23:34+00:00
5985/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
47001/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
49664/tcp open  msrpc          Microsoft Windows RPC
49665/tcp open  msrpc          Microsoft Windows RPC
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
49668/tcp open  msrpc          Microsoft Windows RPC
49669/tcp open  msrpc          Microsoft Windows RPC
49671/tcp open  msrpc          Microsoft Windows RPC
50766/tcp open  msrpc          Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required
|_ smb2-time:
|_ date: 2026-08-05T04:23:35

```

Full Port and Service Scan of Target Host:

Port:	State:	Service:	Version:
21	Open	ftp	Filezilla ftpd 1.12.6
80	Open	http	Microsoft IIS httpd 10.0
135	Open	msrpc	Microsoft Windows RPC
139	Open	netbios-ssn	Microsoft Windows netbios-ssn
445	Open	microsoft-ds	
1433	Open	ms-sql-s	Microsoft SQL Server 2019 15.00.2000.00; RTM
3389	Open	ms-wbt-server	Microsoft Terminal Services
5985	Open	http	Microsoft HTTPAPI

			httpd 2.0 (SSDP/UPnP)
47001	Open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664	Open	msrpc	Microsoft Windows RPC
49665	Open	msrpc	Microsoft Windows RPC
49666	Open	msrpc	Microsoft Windows RPC
49667	Open	msrpc	Microsoft Windows RPC
49668	Open	msrpc	Microsoft Windows RPC
49669	Open	msrpc	Microsoft Windows RPC
49671	Open	msrpc	Microsoft Windows RPC
50766	Open	msrpc	Microsoft Windows RPC

Part 2 Vulnerability Detection:

- Nmap's vulnerability detection script is applied to the banking server-target host (10.10.20.4) to find any outstanding vulnerabilities.
- The resulting output below shows vulnerability in Port 80 with the "http-enum" script.
Referencing the National Vulnerability Database and cross referencing the service: http and version: Microsoft IIS httpd 10.0, a vulnerability is seen:
 - CVE-2019-0941: A denial of service exists in Microsoft IIS Server when the optional request filtering feature improperly handles requests. An attacker who successfully exploited this vulnerability could perform a temporary denial of service against pages configured to use request filtering. Priority: High

- The output shows many open or exposed important ports such as 1433 with the service:ms-sql-s and version: Microsoft SQL Server 2019 15.00.2000.00; RTM. Cross referencing shows the vulnerability:
 - CVE-2022-29143: The vulnerability exists within the SQL Server database engine and is triggered over the network. It requires the attacker to already have valid authentication credentials, who then can do remote code execution. Priority: High

```

(student01@kali)-[~]
└─$ nmap --script vuln 10.10.20.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 04:58 +0000
Nmap scan report for victim.internal.cloudapp.net (10.10.20.4)
Host is up (0.0011s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-enum:
|_  /admin/: Possible admin folder
|_  /admin/index.html: Possible admin folder
|_  /Admin/: Possible admin folder
|_  /backup/: Possible backup
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
1433/tcp   open  ms-sql-s
|_tls-ticketbleed: ERROR: Script execution failed (use -d to debug)
3389/tcp   open  ms-wbt-server
5985/tcp   open  wsman

Host script results:
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

```

Part 4: Mitigation and Remediation

- CVE-2019-0941 Fix:
 - I would recommend patching this vulnerability through vendor updates. In June 2019, Microsoft released a security update with the patch: KB4503289 that changed the way certain requests are processed by the filter which addresses this issue for Microsoft IIS 10.0.
- CVE-2022-29143 Fix:
 - I would also recommend patching this vulnerability through the latest cumulative update. Through the SQL Server 2019 patch: KB5014356, it mitigates the vulnerability by enforcing boundary checks and input validation.

Reflection:

1. The easiest piece of information to find that would help an attacker was the presence of web directories like /admin/ and /backup/ folders that were exposed through the Nmap vulnerability script. This is the case due to a lack of access controls and authentication running within the http

service. This could ultimately lead to an attacker gaining access to important administrative information.

2. If I were defending the host, I would enforce network segmentation first. This would be the priority as the stricter access would protect the exposed critical administrative and database ports in a widespread manner. This measure would be more immediate which would give time for more specific security fixes of these interfaces.
3. I would explain to a non-technical manager that the risk is urgent in that the system's security weaknesses could allow attackers to gain access and steal sensitive banking information. Additionally they could take control of and shutdown databases and the system all together. I would explain that it is necessary to take steps to mitigate these risks to protect customers and the enterprise as a whole.